

CVE-2013-2220 — PHP Radius Extension Buffer Overflow

SEVERITY: HIGH CVSS 7.5 — Remote, unauthenticated, network-exploitable

1. Summary

CVE-2013-2220 describes a buffer overflow vulnerability in the `radius_get_vendor_attr()` function within the Radius extension for PHP, present in versions prior to 1.2.7. The flaw allows a remote, unauthenticated attacker to trigger the vulnerability by supplying an oversized Vendor Specific Attribute (VSA) length value in a RADIUS response. Exploitation can cause the affected application to crash (denial of service) and, depending on memory layout and platform protections, may allow arbitrary code execution in the context of the PHP process handling the RADIUS communication.

2. Vulnerability Details

CVE ID	CVE-2013-2220
Component	PHP Radius extension (php-radius / <code>radius_get_vendor_attr</code> function)
Affected Versions	Versions of the Radius PHP extension prior to 1.2.7
Fixed Version	1.2.7 and later (Debian package fix released in php-radius 1.2.5-2.4)
Vulnerability Type	CWE-119 / Buffer Overflow (stack or heap, based on VSA parsing)
CVSS v2 Base Score	7.5 (High)
CVSS v2 Vector	AV:N/AC:L/Au:N/C:P/I:P/A:P
Attack Vector	Network (remote)
Privileges Required	None
Impact	Denial of Service (application crash); potential arbitrary code execution
Disclosure Date	2013 (public CVE record; Debian bug tracker fix reference included)

3. Technical Description

The PHP Radius extension implements client-side parsing of RADIUS protocol responses, including Vendor Specific Attributes (VSAs) used to carry vendor-defined data within Access-Accept, Access-Reject, and related packets. The `radius_get_vendor_attr()` function reads a length field from the incoming VSA structure and uses it to determine how much data to copy into a fixed-size internal buffer.

Because the function does not adequately validate the attacker-controlled length value against the size of the destination buffer before performing the copy, a malicious or compromised RADIUS server (or an attacker positioned to spoof/intercept RADIUS traffic) can supply a VSA whose declared length exceeds the buffer's actual capacity. This results in a classic length-driven buffer overflow (CWE-119 / CWE-120 family), overwriting adjacent memory in the PHP process.

4. Preconditions and Attack Path

- A target application uses the vulnerable PHP Radius extension (version < 1.2.7) to authenticate against a RADIUS server.
- The attacker controls, spoofs, or performs a man-in-the-middle position on the RADIUS response path (e.g. a rogue/compromised RADIUS server, or the ability to inject UDP responses to the client).
- The attacker crafts a RADIUS response containing a VSA with an oversized declared length value.
- The vulnerable client parses the response via `radius_get_vendor_attr()`, triggering the overflow.

5. Impact

- Denial of Service: the crafted VSA can crash the PHP process performing RADIUS authentication, disrupting authentication services that depend on it.
- Potential Remote Code Execution: depending on compiler mitigations (stack canaries, ASLR, DEP/NX) and the exact memory region overwritten, memory corruption of this type may be leveraged for arbitrary code execution in the security context of the affected process.
- Because the RADIUS client typically underlies authentication flows (VPN, network access control, ISP/dial-up-style auth), a successful DoS or RCE against it can have outsized impact on availability of authentication services.

6. Affected Software

The Radius extension for PHP (commonly packaged as `php-radius`) in versions prior to 1.2.7 is affected. Debian tracked and resolved this issue in package version 1.2.5-2.4, confirming the fix was incorporated for the Debian distribution. Other distributions and manually compiled installations should verify their installed extension version independently.

7. Remediation

- Upgrade the PHP Radius extension to version 1.2.7 or later (or the distribution-patched equivalent, e.g. Debian `php-radius 1.2.5-2.4+`).
- Where upgrading is not immediately possible, restrict which RADIUS servers a client is permitted to communicate with, and ensure RADIUS traffic traverses a trusted, isolated network path to reduce exposure to spoofed or malicious responses.
- Apply RADIUS shared-secret validation and network-layer controls (e.g. firewalling UDP 1812/1813 to known-good RADIUS servers) as defense in depth.
- After patching, verify the fix with a version check (`php -m` or extension version query) and, where feasible, validate behavior against known-bad oversized VSA test packets in a controlled lab environment.
- Monitor RADIUS authentication logs and process stability for crash indicators consistent with attempted exploitation.

8. References

- CVE-2013-2220 — public CVE record
- Debian Bug Tracking System — php-radius package, fixed in version 1.2.5-2.4
- CWE-119: Improper Restriction of Operations within the Bounds of a Memory Buffer

This report documents a publicly disclosed vulnerability for reference and remediation planning purposes. It contains no exploit code and is not associated with any specific host or target system.